Security Incident Report: Simulated Phishing Attack on Northwind Harbor Logistics

Scope and safety statement

This is a tabletop simulation: Northwind Harbor Logistics, its staff, the email and every address below are fictional, and no real person or company was targeted.

Field	Detail
Incident ID	NHL-SIM-2026-1013-01
Organization	Northwind Harbor Logistics (fictional freight forwarder, about 850 staff)
Incident type	Credential-harvesting phishing email (simulated)
Simulated event date	Monday 12 October 2026
Report date	Tuesday 13 October 2026
Severity	High: one set of credentials entered, finance system reachable
Status	Contained in the simulation; follow-up actions open

Safety controls for this exercise: the sender and link domains use the reserved `.example` suffix, which cannot resolve on the internet. Server addresses come from the RFC 5737 documentation ranges. No email was sent, no login page was built, no credentials were collected and no system was tested.

Executive summary

A fake "password expiry" email reached 38 accounts-payable and operations staff at 08:12 on 12 October 2026, and three people entered their credentials on the fake sign-in page before one colleague reported it at 09:02.

The security team confirmed two of the three accounts were used from an unfamiliar address, and one of them gained a hidden mailbox forwarding rule. The team reset passwords, ended active sessions, purged the message and blocked the sender domain by 10:30. A forged bank-detail change request was drafted but stopped by the dual-approval payment rule, so no money moved in this scenario.

The email failed several basic checks (a look-alike domain, urgency, a mismatched link and a failed sender authentication), yet nine people clicked. The main fixes are phishing-resistant multi-factor authentication, stricter email authentication enforcement and a simple one-click reporting habit.

What phishing is and how attackers use it

Phishing is a social-engineering attack in which a criminal poses as a trusted sender to trick a person into handing over credentials, money or access, or into running something harmful. It works because it targets people's habits (trust, speed, deference to authority) rather than software flaws.

A typical attack follows this path:

1. **Research.** The attacker gathers public details such as staff names, job titles, suppliers and the tools a company uses.
2. **Lure.** They send a message that looks routine: a password expiry, an invoice, a shared document or a message from an executive.
3. **Hook.** The message creates pressure (a deadline, a threat, a reward) and offers one easy action, usually a link or an attachment.
4. **Capture.** The link leads to a look-alike sign-in page, or the attachment installs a malicious program, which gives the attacker a password or a foothold.
5. **Abuse.** With a valid login the attacker reads mail, creates hidden forwarding rules, sends further phishing from a trusted account, or redirects payments.
6. **Cash out.** Fraudulent transfers, data theft, resale of access, or ransomware.

Common variants:

Variant	How it works	Typical target
Bulk phishing	Generic message sent to many people	Anyone
Spear phishing	Tailored to one person or team using researched detail	Finance, HR, administrators
Business email compromise	Impersonates an executive or supplier to request payment or data	Accounts payable
Smishing and vishing	Text message or phone call instead of email	Mobile users, help desks
QR-code phishing	A QR code replaces the link so scanners do not see the address	Staff reading printed or emailed codes

Incident timeline (simulated)

The incident ran about two hours and eighteen minutes from delivery to containment; all times are local, in chronological order.

Time	Event
Sun 11 Oct, 22:40	Attacker registers the look-alike domain `northwind-harbor-secure.example` (scenario assumption)
Mon 12 Oct, 08:12	Email delivered to 38 accounts-payable and operations mailboxes
08:12 to 09:00	Nine recipients click the link; three enter their username and password on the fake page
09:02	An accounts-payable analyst reports the email to the help desk by forwarding it
09:15	Security analyst confirms the sender domain is a look-alike and the link does not go to the company sign-in
09:40	Monitoring shows sign-ins to two of the three accounts from an unfamiliar address (`203.0.113.77`), and a forwarding rule on one mailbox

Time	Event
10:05	Passwords reset and all active sessions revoked for the three accounts; the forwarding rule removed
10:30	Message purged from every mailbox, sender domain and link blocked, incident declared contained
11:15	Finance confirms a forged bank-detail change request was held by dual approval; no payment released

Annotated simulated email

The email below shows eight warning signs, marked (1) to (8) and explained in the table beneath it. It is a fictional training sample: the domains cannot resolve, and the link is written in defanged form (hxxps) so it cannot be clicked.

```
From:     "Northwind IT Helpdesk" <it-helpdesk@northwind-harbor-
secure.example>   (1)
Reply-To: support-desk@mailbox-relay.example
(2)
To:       undisclosed-recipients
(3)
Date:     Mon, 12 Oct 2026 08:12
Subject:  [ACTION REQUIRED] Password expires in 2 hours - verify now
(4)

Dear User,
(5)

Our records show your Northwind account password expires today at 10:00.
If you do not verify your account immediately, your mailbox will be
suspended and pending supplier payments will be delayed.
(4)

    [ Verify My Account Now ]
(6)
    Link text shows: https://login.northwind-harbor.example
    Real destination: hxxps://northwind-harbor-sso[.]example/auth/verify?
id=A7731

You will be asked to enter your username and password to confirm.
(7)
```

```
Thank you,
IT Security Team
(8)
This is an automated message. Do not reply.
```

#	Where	Warning sign	Why it matters
1	From address	Look-alike domain `northwind-harbor-secure.example` instead of the real `northwind-harbor.example`	Attackers register near-identical names; the display name "Northwind IT Helpdesk" is easy to fake
2	Reply-To	Replies go to an unrelated domain	Answers would reach the attacker, not the company
3	To line	Recipient is hidden and the message is generic	Real IT notices are usually addressed to you by name or sent through a known system
4	Subject and body	Artificial urgency and a threat (2 hours, suspension, delayed payments)	Pressure is designed to stop you from checking
5	Greeting	"Dear User" with no name	A genuine internal system knows who you are
6	Button	The visible link text does not match the real destination	Hovering over a link reveals where it really goes
7	Request	Asks you to type your password after clicking a link in an email	IT staff never need your password; this is the credential-harvesting step
8	Signature	No named person, phone number or ticket reference, plus "do not reply"	Removes any easy way to verify the sender

A ninth indicator sits in the technical headers rather than the visible message: the sender failed SPF, DKIM and DMARC checks, analysed in the next section.

Bonus: email header analysis (SPF, DKIM, DMARC)

The header shows SPF failed, DKIM passed only for an unrelated domain, and DMARC failed, yet the message was still delivered because the look-alike domain's policy told receivers to take no action. This sample is authored for training; the domains and the

address `203.0.113.45` are reserved for documentation.

```
Received: from relay7.mailbox-relay.example (relay7.mailbox-relay.example
[203.0.113.45])
        by mx.northwind-harbor.example with ESMTPS; Mon, 12 Oct 2026 08:12:03
+0100
Authentication-Results: mx.northwind-harbor.example;
        spf=fail smtp.mailfrom=it-helpdesk@northwind-harbor-secure.example
            (203.0.113.45 is not a permitted sender);
        dkim=pass header.d=mailbox-relay.example header.s=s2026;
        dmarc=fail (p=none) header.from=northwind-harbor-secure.example
Return-Path: <it-helpdesk@northwind-harbor-secure.example>
From: "Northwind IT Helpdesk" <it-helpdesk@northwind-harbor-secure.example>
Reply-To: support-desk@mailbox-relay.example
Message-ID: <20261012081203.A7731@relay7.mailbox-relay.example>
```

The three checks answer different questions:

- **SPF (Sender Policy Framework)** checks whether the sending server's IP address is listed in the DNS record of the envelope sender's domain.
- **DKIM (DomainKeys Identified Mail)** checks a cryptographic signature that proves a domain signed the message and that it was not altered in transit.
- **DMARC (Domain-based Message Authentication, Reporting and Conformance)** requires SPF or DKIM to pass *and* align with the visible From domain, then applies the domain owner's policy: none, quarantine or reject.

Check	Result	Reading
SPF	Fail	The relay at `203.0.113.45` is not authorized to send for `northwind-harbor-secure.example`
DKIM	Pass, but for `mailbox-relay.example`	The signature is valid, yet it belongs to a different domain than the one in the From line, so it proves nothing about the sender's identity
DMARC	Fail (`p=none`)	No passing check aligned with the From domain; the policy `p=none` means "report but still deliver"

Other header clues: the Message-ID and Reply-To both point at `mailbox-relay.example`, which does not match the From domain, and the first Received hop is an external relay, not any Northwind system.

Two lessons follow. First, a DKIM "pass" is meaningless unless the signing domain matches the From domain. Second, Northwind's own DMARC record protects only `northwind-harbor.example`; a look-alike domain controlled by an attacker can even pass all three checks on its own. Authentication results therefore help but cannot replace domain monitoring, an external-sender warning banner and user judgement.